

HIPAA BUSINESS ASSOCIATE ADDENDUM

Version 2026-08-11

This HIPAA Business Associate Addendum (this "Addendum") is made as of the date an authorized signer completes electronic signature through Refidly's in-product signing flow (the "Effective Date"), by and between [_____] a [_____] [corporation / limited liability company / other] having its principal offices at [_____] ("Customer" or "Covered Entity"), and Refidly, a product of InnovareHP ("Refidly" or "Business Associate"). This Addendum is expressly made part of, and incorporated into, the Refidly Customer Agreement between the parties (the "Agreement"), and applies only where Customer subscribes to a plan for which Refidly offers a BAA.

Background

A. Customer is a Covered Entity, or is a Business Associate to a Covered Entity, and wishes to create, receive, maintain, or exchange Protected Health Information through the Service.

B. Refidly creates, receives, maintains, and transmits PHI on Customer's behalf in a manner that makes Refidly a Business Associate under HIPAA rather than a transmission-only conduit, and the parties agree Refidly will perform, and be bound by, the full obligations of a Business Associate set out in this Addendum.

C. The purpose of this Addendum is to satisfy the applicable standards and requirements of HIPAA, the HITECH Act, and the HIPAA Regulations with respect to the Service.

1. Definitions

Terms used but not otherwise defined in this Addendum have the meanings given in HIPAA, the HITECH Act, or the HIPAA Regulations, as applicable.

- "Breach" has the meaning given in 45 C.F.R. § 164.402, subject to the exclusions set out there.
- "Breach Notification Rule" means Subpart D of 45 C.F.R. Part 164, together with the related provisions of Part 160 and Subpart A of Part 164.
- "Business Associate" and "Covered Entity" have the meanings given in 45 C.F.R. § 160.103.
- "Data Aggregation" and "Designated Record Set" have the meanings given in 45 C.F.R. § 164.501.
- "De-Identify" means to alter PHI so that the result meets the requirements of 45 C.F.R. § 164.514(a) and (b).
- "Disclosure" and "Disclose" have the meanings given in 45 C.F.R. § 160.103.
- "Electronic PHI" has the meaning given in 45 C.F.R. § 160.103.
- "HIPAA" means the Health Insurance Portability and Accountability Act of 1996, and "HITECH Act" means Subtitle D of the Health Information Technology for Economic and Clinical Health Act, 42 U.S.C. §§ 17921-17953; the Privacy Rule, Security Rule, and Breach Notification Rule issued thereunder are the "HIPAA Regulations."
- "Individual" has the meaning given in 45 C.F.R. § 160.103, including a personal representative under 45 C.F.R. § 164.502(g).
- "Privacy Rule" means Subpart E of 45 C.F.R. Part 164; "Security Rule" means Subpart C of 45 C.F.R. Part 164.



- "PHI" or "Protected Health Information" has the meaning given in 45 C.F.R. § 160.103.
- "Security Incident" has the meaning given in 45 C.F.R. § 164.304.
- "Subcontractor" has the meaning given in 45 C.F.R. § 160.103, and "Unsecured PHI" the meaning given in 45 C.F.R. § 164.402.
- "Service" means the Refidly platform made available to Customer under the Agreement, including its referral and facility records, custom fields, notes and attachments, field activity logs, calendar and booking tools, outreach and fax delivery, analytics, exports, and AI-assisted features.

2. Obligations and Activities of Business Associate

Refidly will:

- not use or disclose PHI other than as permitted or required by this Addendum or as required by law;
- use appropriate administrative, physical, and technical safeguards, and comply with the Security Rule with respect to Electronic PHI, to prevent use or disclosure other than as provided for by this Addendum;
- maintain those safeguards as described in the Agreement, including encryption of PHI in transit and at rest, access control scoped to Customer's own organization, unique user identification, a second authentication factor for access to PHI, optional network allowlisting under Customer's control, and audit logging of record changes;
- report to Customer, without unreasonable delay and in no event later than 60 calendar days after discovery, any use or disclosure of PHI not permitted by this Addendum, any Security Incident of which it becomes aware, and any Breach of Unsecured PHI, in accordance with the Breach Notification Rule, including to the extent known the individuals affected, the nature of the incident, the PHI involved, and the mitigation and corrective steps taken;
- report unsuccessful attempts at unauthorized access that do not result in unauthorized access to PHI on an aggregate basis on request;
- ensure that any Subcontractor that creates, receives, maintains, or transmits PHI on Refidly's behalf, including hosting, storage, fax delivery, and AI processing providers, agrees in writing to restrictions and conditions at least as protective as those in this Addendum, and remain responsible for their handling of PHI;
- make PHI in a Designated Record Set available to Customer within 10 business days of a request, so Customer can respond to an Individual's access request under 45 C.F.R. § 164.524;
- make PHI available for amendment, and incorporate any amendment Customer directs, in accordance with 45 C.F.R. § 164.526;
- maintain and make available the information required to provide an accounting of disclosures under 45 C.F.R. § 164.528, and forward to Customer any request an Individual makes directly to Refidly;
- make its internal practices, books, and records relating to the use and disclosure of PHI available to the Secretary of Health and Human Services for purposes of determining Customer's compliance with HIPAA; and
- mitigate, to the extent practicable, any harmful effect known to Refidly of a use or disclosure of PHI in violation of this Addendum.



3. Permitted Uses and Disclosures by Business Associate

Except as otherwise limited in this Addendum, Refidly may use and disclose PHI (a) to perform the Service under the Agreement; (b) for Refidly's proper management and administration, or to carry out its legal responsibilities, provided any disclosure to a third party is either required by law or subject to reasonable assurances of confidentiality and prompt notification of any known breach; (c) to provide Data Aggregation services relating to Customer's health care operations, if requested; and (d) to De-Identify PHI in accordance with 45 C.F.R. § 164.514, after which the resulting information is no longer PHI and is not subject to this Addendum.

- Refidly shall make reasonable efforts to use, disclose, and request only the minimum necessary PHI to accomplish the intended purpose.
- Refidly shall not sell PHI, and shall not use or disclose PHI for marketing purposes, except as permitted by HIPAA and authorized in writing by Customer.
- AI-assisted features transmit workspace content to an AI subprocessor only when a user triggers them. That processing is transient, remains scoped to Customer's organization, and no workspace content is used to train any Refidly or third-party model. AI output is decision support and is not a clinical determination.
- Outreach email is transmitted through the mailbox Customer's user connects, under Customer's own sending identity. Refidly does not select the recipients of, or the content placed in, those messages.

4. Obligations of Covered Entity

Customer will (a) provide Refidly only with PHI reasonably necessary for Refidly to perform the Service, consistent with the minimum-necessary standard; (b) notify Refidly of any limitation in its notice of privacy practices, or any restriction or revocation of an Individual's authorization, to the extent it affects Refidly's use or disclosure of PHI; and (c) not request that Refidly use or disclose PHI in a way that would not be permitted under the Privacy Rule if done by Customer directly, except as permitted under Section 3 for Data Aggregation or management functions.

- Customer configures its own custom fields and is responsible for what those fields are used to hold. Customer shall not place PHI in the Service before this Addendum is in effect.
- Customer is responsible for provisioning and deprovisioning its own users, for the roles and permissions it assigns them, and for the lawfulness of the PHI it submits.
- Customer is responsible for the content, recipients, and consent basis of the outreach and fax communications it sends through the Service, and for its own compliance with the Privacy Rule when doing so.
- Customer selects the retention period applied to its records and is responsible for choosing one consistent with its own legal and professional obligations.

5. Term and Termination

5.1 Conditions to validity. This Addendum is valid and binding only once (a) an authorized signer for Customer has completed electronic signature as described under Signatures, and (b) Customer maintains an active subscription to a plan for which Refidly offers a BAA. An Addendum signed in anticipation of an upgrade does not take effect until both conditions are satisfied.

5.2 Term coextensive with billing cycle. This Addendum's effectiveness runs coextensively with Customer's then-current billing cycle under the Agreement, and renews automatically, without a new signature, upon each



timely renewal payment for a BAA-eligible plan.

5.3 Automatic lapse. This Addendum automatically lapses, without further action by either party, if (a) Customer's plan is changed to one for which Refidly does not offer a BAA, (b) the Agreement is cancelled or terminated, or (c) payment for the then-current billing cycle is not made and the Service is suspended for non-payment after notice. A lapse does not itself terminate the Agreement, but Customer may not place or process PHI in the Service while this Addendum has lapsed.

5.4 Overall term and breach. Subject to Sections 5.1 through 5.3, this Addendum takes effect on the Effective Date and terminates automatically when the Agreement terminates, or when all PHI held by Refidly has been returned or destroyed under Section 6, whichever is later. If either party learns of a material breach of this Addendum by the other, the non-breaching party will notify the breaching party in writing, and the breaching party will have 30 days to cure. If the breach is not cured within that period, the non-breaching party may terminate the Agreement and this Addendum for cause, in addition to any other remedies available at law.

6. Effect of Termination

On termination of this Addendum, Refidly will, at Customer's election, return or destroy all PHI it maintains and retain no copies, except that (a) where return or destruction is not feasible, Refidly will extend the protections of this Addendum to the PHI retained and limit further uses and disclosures to those purposes that make return or destruction infeasible, for as long as Refidly maintains the PHI; and (b) Refidly may retain PHI within backups and audit records as described in the Agreement, which remain subject to this Addendum until they expire under the applicable retention schedule. Destruction is carried out in a manner that renders the PHI unreadable and unreconstructable.

7. Indemnification and Liability

Refidly will defend and indemnify Customer against third-party claims, fines, or penalties arising from Refidly's failure to perform its obligations as Business Associate under this Addendum, including a Breach caused by Refidly's failure to implement the safeguards described in Section 2. This indemnification obligation is not subject to the general liability cap in the Agreement to the extent such a limitation would be unenforceable under applicable law. Customer will indemnify Refidly as provided in the Agreement for PHI placed in the Service outside the scope of this Addendum, including on a plan for which no BAA has been executed.

8. Miscellaneous

The parties will amend this Addendum as necessary for Customer to comply with HIPAA, the HITECH Act, and the HIPAA Regulations.

- Interpretation: any ambiguity in this Addendum will be resolved in favor of an interpretation that permits compliance with the HIPAA Regulations, and a reference to a section of HIPAA means that section as in effect or as amended.
- No third-party beneficiaries: nothing in this Addendum confers any rights on any person other than the parties.
- Survival: obligations relating to the return, destruction, or continued protection of PHI, and indemnification for acts occurring before termination, survive termination of this Addendum.
- Order of precedence: in the event of a conflict between this Addendum and the Agreement, this Addendum controls with respect to PHI.



- Governing law: this Addendum is governed by the law of the jurisdiction of Customer's formation, without regard to its conflict of laws rules.

Signatures

The parties agree that electronic signatures, including a signature drawn or otherwise captured through Refidly's in-product signing flow, satisfy any requirement of a written or handwritten signature under the U.S. E-SIGN Act and applicable state equivalents (UETA). This Addendum is executed when an authorized signer for Customer completes that flow against the countersignature of Refidly recorded below. The signed PDF and associated signing record, including signer name, title, email, network address, and timestamp, retained by Refidly constitute the authoritative record of acceptance.

